

ĐỀ CƯƠNG CHI TIẾT ĐỒ ÁN TỐT NGHIỆP

KHOA CÔNG NGHỆ THÔNG TIN — BỘ MÔN KỸ THUẬT PHẦN MỀM

PHẦN A — Thông tin đề tài

Tên tiếng Việt

Cơ chế ủy quyền ràng buộc giao dịch cho hành động của tác tử AI trong hệ thống ERP: Thiết kế và đánh giá trên Odoo 17

Tên tiếng Anh

Transaction-Bound Authorization for AI-Agent Actions in ERP: Design and Evaluation on Odoo 17

- Ngành đào tạo: Kỹ thuật Phần mềm (Software Engineering).
- Loại hình: Nghiên cứu ứng dụng và phát triển hệ thống.
- Thời gian dự kiến: 16 tuần trong học kỳ tốt nghiệp.
- Sinh viên thực hiện:; MSSV:; Lớp:
- Cán bộ hướng dẫn:

PHẦN B — Nội dung thuyết minh

Tuyên bố luận đề

Đồ án thiết kế và đánh giá cơ chế ủy quyền ràng buộc giao dịch cho hành động của tác tử AI. Trong phạm vi nghiên cứu, AI agent là một chủ thể phần mềm không phải con người (non-human software principal), gọi công cụ nghiệp vụ thay mặt người dùng thông qua ủy quyền được kiểm soát. Đề tài nghiên cứu ranh giới authorization, không đánh giá chất lượng suy luận hay huấn luyện mô hình.

Bất biến trung tâm là: giao dịch được bảo vệ chỉ được commit khi danh tính tin cậy, ủy quyền một-hop, ý định nghiệp vụ chuẩn hóa, trạng thái ERP, policy/revocation và phê duyệt bắt buộc đều vượt qua kiểm tra; command và approval được tiêu thụ nguyên tử với thay đổi nghiệp vụ. Hiện thực dùng khóa và fence để sắp thứ tự các thay đổi được cấu hình trong Odoo/PostgreSQL. Thời hạn được kiểm tra tại bước deferred validation của PostgreSQL, không phải thời điểm WAL bền vững hay phản hồi đến client.

Miền thực nghiệm chỉ gồm một đường xác nhận đơn mua hàng purchase.order trên Odoo 17. Go PDP là nền tảng hiện thực; hiệu năng hỗ trợ đánh giá tính khả thi.

I — Câu hỏi nghiên cứu

- **RQ1:** Làm thế nào biểu diễn và kiểm chứng agent hành động thay mặt human principal trong cùng tenant, theo scope, thời hạn và ràng buộc nghiệp vụ của ủy quyền một-hop?
- **RQ2:** Làm thế nào ràng buộc quyền với đúng canonical business intent và trạng thái ERP tại ranh giới commit, để phát hiện thay đổi tham số, replay và TOCTOU?
- **RQ3:** Làm thế nào gắn phê duyệt với đúng hành động, kiểm tra Separation of Duties (SoD), và ngăn thay thế, tự phê duyệt hoặc sử dụng lại approval?
- **RQ4:** Trên cùng workflow, fixture và môi trường, cơ chế đề xuất khác broad service account và policy-only ra sao về tính đúng đắn bảo mật và chi phí thực thi?

II — Vấn đề và phạm vi đóng góp

Khi agent gọi công cụ ERP, quyền gọi API chưa đủ để xác định một thay đổi nghiệp vụ cụ thể có được phép thực hiện hay không. Request có thể bị sửa, approval có thể thuộc một phiên bản đơn khác, quyền có thể thay đổi trong lúc xử lý, hoặc client có thể gửi lại request sau mất phản hồi.

OWASP LLM06:2025 xác định excessive functionality, permissions và autonomy là nguồn rủi ro; các biện pháp được nêu gồm giới hạn quyền, thực thi trong ngữ cảnh người dùng, phê duyệt hành động tác động cao và kiểm soát tại hệ thống downstream [4]. Đề án chọn nghiên cứu lớp kiểm soát hành động đó, không tuyên bố giải quyết mọi prompt injection.

Khoảng trống kỹ thuật được khảo sát là sự kết hợp giữa delegated authorization và tính toàn vẹn của giao dịch ERP. Một policy check tách rời không tự tạo ra ràng buộc nguyên tử với mutation. Đề án không khẳng định mọi hệ thống hiện hữu đều thiếu cơ chế này hoặc đề xuất là hoàn toàn mới; đối chiếu related work và giới hạn tính mới phải được lập luận trong luận văn.

Xác nhận đơn mua hàng là trường hợp thực nghiệm có amount, currency, vendor, lines, trạng thái và approval để quan sát. Đây không phải nghiên cứu toàn bộ Procure-to-Pay, thanh toán hoặc quản lý ERP tự động.

III — Cơ sở lý thuyết và nghiên cứu liên quan

- ABAC [1] hỗ trợ diễn đạt quyền theo thuộc tính chủ thể, tài nguyên, hành động và môi trường. Zero Trust [2] cung cấp bối cảnh về quyết định truy cập, không chứng minh invariant giao dịch của đề án.
- NIST AI RMF [3] cung cấp bối cảnh quản trị rủi ro; OWASP [4] định hướng kiểm soát excessive agency. Viện dẫn các tài liệu này không đồng nghĩa đạt chứng nhận hay compliance.
- XACML [5] giúp đối chiếu việc tách điểm quyết định và điểm thực thi. Cedar [6] là tham khảo về ngôn ngữ authorization; không kế thừa tuyên bố verification hoặc ưu thế hiệu năng của Cedar cho PDP này.
- Zanzibar [7] là tham khảo về consistency của authorization. Đề án không tái hiện kiến trúc phân tán hoặc quy mô triển khai của hệ thống đó.
- Cơ chế transaction, khóa, idempotency và SoD được sử dụng để đặc tả boundary Odoo/PostgreSQL. SAP chỉ xuất hiện trong phân tích khả năng áp dụng, không có tích hợp runtime.

IV — Mục tiêu và ranh giới nghiên cứu

Nền tảng kế thừa	Vai trò trong đề tài
Go PDP, policy evaluator, role graph và gRPC/mTLS	Hạ tầng quyết định quyền và truyền thông; không phải đóng góp học thuật chính.
Odoo ORM, purchase workflow và PostgreSQL	Nguồn trạng thái nghiệp vụ có thẩm quyền và ranh giới mutation.
Testbed, unit tests và integration runners	Cơ sở tái lập, không tự chứng minh phạm vi lớn hơn từng phép kiểm thử.

Phạm vi thực hiện gồm một-hop human-to-agent delegation trong cùng tenant; canonical intent và material-state witness; purpose-separated proof/capability; exact-action approval và SoD; locked revalidation, atomic consumption, retry/concurrency và đánh giá có đối chứng.

Ngoài phạm vi: multi-hop/multi-agent orchestration; huấn luyện hoặc chọn model; prompt filtering; SAP runtime; toàn bộ ERP; production certification; chống chối bỏ bằng shared-key HMAC; distributed atomic transaction; exactly-once external side effects; dynamic HR hoặc daily-limit không có nguồn và thực nghiệm tương ứng.

V — Thiết kế và phương pháp nghiên cứu

Luồng tin cậy được giới hạn như sau:

1. Human principal cấp delegation; agent gửi đề xuất gọi tool.

2. Odoo PEP lấy dữ liệu authoritative và dựng Canonical Business Intent (CBI). Agent không được tự khai báo amount/vendor/lines như nguồn sự thật. Tiền được biểu diễn bằng số nguyên đơn vị nhỏ nhất tại boundary.
3. PDP kiểm tra danh tính, delegation và policy, trả ALLOW hoặc DENY.
4. Nếu ALLOW kèm REQUIRE_HUMAN_APPROVAL, Odoo lưu trạng thái to approve và pending intent, kết thúc transaction trước khi chờ người duyệt. Activity chỉ là thông báo.
5. Người duyệt độc lập được kiểm tra quyền và SoD; capability gắn đúng intent hash, witness và thời hạn.
6. Đường cuối khóa và đọc lại trạng thái, kiểm tra proof/capability cùng quyền hiện hành, rồi tiêu thụ command/approval và thay đổi PO trong cùng transaction. ALLOW không cần approval đi theo đường cuối trực tiếp; DENY luôn là từ chối cứng, kể cả khi có obligation.

Ba lớp đóng góp:

- **Đóng góp 1 — Delegation-aware authorization:** mô hình human, agent, tenant, scope, validity và constraints; xác định nguồn tin cậy cho từng thuộc tính (RQ1).
- **Đóng góp 2 — Transaction binding:** CBI, material-state witness, proof versioning, phát hiện tamper và replay đối với đúng giao dịch (RQ2).
- **Đóng góp 3 — Commit-time enforcement:** revalidation dưới khóa, exact-action approval, SoD và one-time consumption nguyên tử với mutation trong phạm vi bảo vệ (RQ3).

Khung đánh giá tái lập trả lời RQ4 và kiểm chứng ba lớp đóng góp; không tách thành một đóng góp cơ chế thứ tư. Trie, DAG, AST evaluator, gRPC và mTLS là lựa chọn hiện thực.

Phương pháp gồm đặc tả threats/invariants, hiện thực Go/Odoo, golden vectors xuyên ngôn ngữ, kiểm thử âm với oracle trạng thái bền vững và lịch xen kẽ hai session. Với policy/role publication và revocation, mọi writer thuộc phạm vi phải dùng cùng ERP fence; local-authority epoch và trigger phải còn nguyên vẹn. Deadline dùng clock PostgreSQL được tin cậy. Không giữ row lock khi chờ human approval.

VI — Kế hoạch 16 tuần

Kế hoạch dưới đây là cấu trúc học kỳ, không phải danh sách yêu cầu làm lại phần đã hoàn tất. Tiến độ thực tế theo task board.

Giai đoạn	Công việc	Thời gian	Đầu ra
1	Chốt RQ, scope, threats và invariants	Tuần 1–2	Đề cương và matrix
2	Đặc tả delegation, CBI, witness và capability	Tuần 3–4	Contract và golden vectors
3	Hiện thực proof, pending approval và SoD	Tuần 5–8	Code và focused tests
4	Commit enforcement, rollback, retry và concurrency	Tuần 9–11	Bảng chứng Odoo/PostgreSQL
5	So sánh A/B/C, đo boundary và phân tích giới hạn	Tuần 12–14	Raw results, trả lời RQ4

Giai đoạn	Công việc	Thời gian	Đầu ra
6	Viết luận văn, đối chiếu claims và luyện bảo vệ	Tuần 15–16	Luận văn, phụ lục, slide

VII — Đánh giá và evidence hiện tại

VERIFIED V2 trong phạm vi giới hạn, ngày 2026-09-27: gate Odoo 17/mTLS/PDP/PostgreSQL chạy trên worktree chưa commit đạt 75 post-tests, không có failure/error. Các runner riêng kiểm tra concurrency/retry, 16 lịch sửa material state, ba lịch grant ordering, ba thay đổi authority trước final, bốn lịch policy/role sau ALLOW và hai trường hợp grant hết hạn theo clock thật tại deferred validation.

25 ID trong matrix có bằng chứng ghép theo từng boundary; không được diễn giải thành 25 kiểm thử ERP end-to-end độc lập hoặc chứng minh an toàn tổng quát. Lệnh, lỗi trước đó và source fingerprint được lưu trong EVAL-01 ledger. Cập nhật tài liệu này không tạo thêm bằng chứng runtime.

VERIFIED V2 trong phạm vi giới hạn: EVAL-02 ghi nhận 11 scenario × 3 variant bằng committed/fresh-observer outcomes. EVAL-03 ghi phân phối tách rời cho Go API/control và các boundary Odoo, kèm raw samples, hash và môi trường. EVAL-04 khóa claim-to-evidence và threats to validity. Các kết quả này không chứng minh ưu thế phổ quát, causal approval overhead, speedup hoặc production SLA.

Nhóm đánh giá	Phép đo hoặc oracle
Functional	Delegation, approval lifecycle, trạng thái PO/command/capability sau transaction
Adversarial	Tamper, wrong authority, reuse, revocation, outage và races; trường hợp âm phải không có unauthorized persistent mutation
Comparison	A: broad service account; B: policy-only; C: cơ chế đề xuất, với khả năng và giới hạn ghi rõ
Performance	Tách evaluator, proof/capability, gRPC/mTLS, locked reconstruction và ERP mutation; raw samples, p50/p95/p99/max, errors, môi trường và revision

Giới hạn thực nghiệm gồm một workflow, tập fixture hữu hạn, writer được cấu hình và các trigger/clock được tin cậy. Chi phí tranh chấp của coarse authority epoch chưa đo; phục hồi publication thủ công chưa được xác minh end-to-end. Một lần UNAVAILABLE ở RPC đầu trong lần chạy trước chưa được giải thích đầy đủ dù clean gate sau đó đã pass. Không suy diễn production readiness hay độ sẵn sàng tổng quát.

Các mốc VERIFIED BASELINE, DESIGNED V2, PLANNED V2 và VERIFIED V2 không thay thế nhau. Current-state audit và scope alignment xác định giới hạn dùng evidence khi viết.

VIII — Bố cục luận văn

- **Chương 1:** Bối cảnh, vấn đề, scope Odoo-first, RQ1–RQ4 và giới hạn đóng góp.
- **Chương 2:** Authorization, delegation, SoD, threats, trust boundaries và related work.
- **Chương 3:** Mô hình delegation, CBI/proof, capability và invariant tại commit.
- **Chương 4:** Hiện thực Go/Odoo, fences, state machine, rollback/retry và kiểm thử thực thi.
- **Chương 5:** Kết quả đúng đắn, A/B/C và overhead; threats to validity, câu trả lời RQ và applicability sang SAP.

SAP không được coi là đã tương thích, đã chạy hoặc có hiệu quả tương đương. Hướng nghề nghiệp là phát triển năng lực SE cho ERP backend/integration; không dùng đồ án làm cam kết tuyển dụng hay dự báo chắc chắn đến 2029.

IX — Tài liệu tham khảo

- [1] Hu, V. C., et al. NIST SP 800-162, Guide to Attribute Based Access Control (ABAC) Definition and Considerations, 2014, cập nhật 2019. NIST.
- [2] Rose, S., et al. NIST SP 800-207, Zero Trust Architecture, 2020. NIST.
- [3] NIST. Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, 2023. NIST.
- [4] OWASP Foundation. LLM06:2025 Excessive Agency. OWASP GenAI.
- [5] OASIS. eXtensible Access Control Markup Language (XACML) Version 3.0, 2013. OASIS specification.
- [6] Cutler, J. W., et al. Cedar: A New Language for Expressive, Fast, Safe, and Analyzable Authorization, OOPSLA 2024. Extended version.
- [7] Pang, R., et al. Zanzibar: Google's Consistent, Global Authorization System, USENIX ATC 2019. USENIX.

Xác nhận của bộ môn

Cán bộ hướng dẫn: (Ký và ghi rõ họ tên)

Trưởng bộ môn: (Ký và ghi rõ họ tên)

Ngày tháng năm